

Plan de Respuesta a Incidente de Ransomware Basado en NIST

Caso de Estudio: TechCo

Alumno: José Manuel Calvo

1. Introducción

La empresa ficticia TechCo sufrió un ataque de ransomware que comprometió servidores críticos, bases de datos de clientes y sistemas de respaldo. El incidente evidenció debilidades importantes en la seguridad de la organización, especialmente en segmentación de red, monitoreo y protección de backups.

Este documento desarrolla un Plan de Respuesta a Incidentes basado en el marco de ciberseguridad del National Institute of Standards and Technology (NIST CSF), estructurado en las funciones:

- Identificar
- Proteger
- Detectar
- Responder
- Recuperar
- Mejorar continuamente

El objetivo es minimizar el impacto operativo, financiero y reputacional de futuros ataques de ransomware.

2. Identificación (Identify)

2.1 Activos Críticos Afectados

Los principales activos comprometidos en TechCo fueron:

Activo	Impacto
Servidor de archivos	Pérdida de acceso a documentos operativos
Base de datos de clientes	Riesgo de fuga de información financiera y personal
Sistemas de backup	Imposibilidad de restaurar información
Infraestructura de red interna	Propagación lateral del malware
Servicios en la nube	Posible interrupción de operaciones
Equipos de empleados	Punto inicial de infección

2.2 Vulnerabilidades Identificadas

Vulnerabilidades técnicas

- Falta de segmentación de red.
- Backups conectados a la misma red productiva.
- Ausencia de monitoreo en tiempo real.
- Falta de soluciones EDR/XDR.
- Sistemas posiblemente desactualizados.
- Escaso control de privilegios.

Vulnerabilidades humanas

- Falta de capacitación en phishing.
- Ausencia de simulaciones de ingeniería social.
- Procesos deficientes de validación de correos.

Vulnerabilidades organizacionales

- No existía un plan formal de respuesta a incidentes.
- No se definieron roles ni responsabilidades.
- No había procedimientos de continuidad operativa.

3. Protección (Protect)

3.1 Medidas Preventivas Recomendadas

Seguridad del correo electrónico

- Implementar filtros anti-phishing y sandboxing.
- Configurar SPF, DKIM y DMARC.(Protocolos de seguridad de correo)
- Bloquear archivos ejecutables sospechosos.

Capacitación del personal

- Formación continua en ciberseguridad.
- Simulaciones periódicas de phishing.
- Concienciación sobre ingeniería social.

Segmentación de red

Separar:

- Servidores críticos.
- Equipos de usuario.
- Bases de datos.
- Sistemas de backup.

Esto limita la propagación lateral del ransomware.

3.2 Protección de Backups

Aplicar la estrategia:

Regla 3-2-1

- 3 copias de los datos.
- 2 medios diferentes.
- 1 copia offline o inmutable.

Recomendaciones

- Backups cifrados.
- Almacenamiento offline.
- Pruebas regulares de restauración.
- Acceso restringido a repositorios de respaldo.

3.3 Controles de Seguridad

Control	Objetivo
MFA (autenticación multifactor)	Evitar accesos no autorizados
EDR/XDR	Detección y contención avanzada
Gestión de parches	Reducir vulnerabilidades
Principio de mínimo privilegio	Limitar propagación
Firewall interno	Control de tráfico lateral
Zero Trust	Validación continua de accesos

La adopción de un modelo Zero Trust habría permitido a TechCo aplicar controles de acceso estrictos, segmentación de red y verificación continua de usuarios y dispositivos, reduciendo significativamente la propagación del ransomware dentro de la infraestructura corporativa.

La ausencia de controles de tráfico lateral permitió que el ransomware se propagara libremente dentro de la red corporativa de TechCo, comprometiendo servidores críticos y sistemas de respaldo. La implementación de segmentación de red, firewalls internos y políticas Zero Trust habría reducido significativamente el alcance del incidente

4. Detección (Detect)

4.1 Métodos de Detección Temprana

TechCo debió implementar:

SIEM

Herramientas de correlación de eventos como:

- Splunk Enterprise Security
- Microsoft Sentinel
- IBM QRadar

EDR/XDR

Monitoreo de endpoints para detectar:

- Cifrado masivo de archivos.
- Procesos sospechosos.
- Movimiento lateral.
- Ejecución de malware.

Ejemplos:

- CrowdStrike Falcon
- Microsoft Defender for Endpoint

4.2 Indicadores de Compromiso (IoC)

Algunos IoC relevantes:

- Incremento inusual de uso de CPU/disco.
- Renombramiento masivo de archivos.
- Extensiones desconocidas.

- Desactivación de antivirus.
- Conexiones sospechosas externas.
- Creación de cuentas administrativas no autorizadas.

La identificación temprana de indicadores de compromiso (IoC), como el incremento inusual del uso de CPU, el cifrado masivo de archivos, conexiones externas sospechosas y la creación de cuentas administrativas no autorizadas, habría permitido a TechCo detectar y contener el ataque de ransomware antes de su propagación completa. Actualmente existen herramientas que ayudan a detectar IoC como Splunk Enterprise Security, Microsoft Sentinel, CrowdStrike Falcon, Wazuh, etc.

4.3 Sistema de Alertas Tempranas

TechCo debe implementar:

- Alertas automáticas SIEM.
- Monitoreo 24/7.
- Dashboards SOC.
- Escalamiento automático de incidentes.
- Respuesta automatizada SOAR.

TechCo debe implementar un sistema de alertas tempranas basado en SIEM, monitoreo continuo, dashboards SOC y automatización SOAR, con el fin de detectar actividades maliciosas en tiempo real, reducir los tiempos de respuesta y contener rápidamente futuros incidentes de ransomware

5. Respuesta (Respond)

5.1 Objetivos de la Respuesta

- Contener el ataque.
- Evitar propagación.
- Preservar evidencia.
- Restaurar operaciones críticas.
- Comunicar adecuadamente el incidente.

5.2 Equipo de Respuesta a Incidentes (CSIRT)

Rol	Responsabilidad
CISO	Dirección estratégica
Equipo SOC	Monitoreo y análisis
Administradores TI	Aislamiento y recuperación
Equipo Legal	Cumplimiento normativo
RRHH	Comunicación interna
Relaciones Públicas	Comunicación externa
Dirección Ejecutiva	Toma de decisiones críticas

5.3 Procedimiento de Respuesta

Fase 1: Contención inmediata

Acciones:

- Desconectar sistemas infectados.
- Bloquear accesos comprometidos.
- Aislar segmentos afectados.
- Suspender conexiones VPN si es necesario.

Fase 2: Análisis

Determinar:

- Vector inicial de ataque.
- Alcance de la infección.
- Sistemas afectados.
- Tipo de ransomware.
- Datos potencialmente exfiltrados.

Fase 3: Erradicación

- Eliminar malware.
- Reinstalar sistemas comprometidos.
- Aplicar parches.
- Cambiar credenciales.
- Revocar accesos sospechosos.

Fase 4: Comunicación

Comunicación interna

Informar:

- Estado del incidente.
- Acciones requeridas.
- Restricciones operativas.

Comunicación externa

Notificar:

- Clientes afectados.
- Autoridades regulatorias.
- Socios estratégicos.
- Medios, si aplica.

5.4 Política sobre Pago de Rescate

TechCo debe:

- Evitar pagar rescates siempre que sea posible.
- Evaluar riesgos legales y financieros.
- Coordinar decisiones con autoridades y expertos forenses.

El pago no garantiza recuperación ni evita filtraciones.

6. Recuperación (Recover)

6.1 Restauración de Sistemas

Prioridad:

- 1. Infraestructura crítica.
- 2. Bases de datos.
- 3. Servicios al cliente.
- 4. Sistemas secundarios.

6.2 Estrategia de Recuperación

Recuperación segura

- Restaurar desde backups offline verificados.
- Validar integridad antes de producción.
- Monitorear reinfecciones.

Validación

- Escaneo antimalware completo.
- Revisión de logs.
- Auditoría de accesos.

6.3 Continuidad del Negocio

TechCo debe disponer de:

Elemento	Objetivo
Plan BCP	Continuidad operativa
Plan DRP	Recuperación ante desastres
Sitios alternos	Alta disponibilidad
Infraestructura redundante	Minimizar interrupciones

TechCo debe implementar un Plan de Continuidad del Negocio (BCP) y un Plan de Recuperación ante Desastres (DRP), complementados con infraestructura redundante y sitios alternos, con el objetivo de garantizar la disponibilidad de servicios críticos y minimizar interrupciones operativas durante incidentes de ransomware.

6.4 Recuperación de la Confianza

- Transparencia con clientes.
- Informes de acciones correctivas.
- Auditorías externas.
- Refuerzo de controles de seguridad.

7. Mejora Continua

7.1 Evaluación Post-Incidente

Realizar:

- Reuniones “Lessons Learned”.
- Evaluación de tiempos de respuesta.
- Análisis de errores.
- Revisión de efectividad de controles.

7.2 Métricas de Evaluación

Métrica	Objetivo
Tiempo de detección	Reducir exposición
Tiempo de contención	Limitar impacto
Tiempo de recuperación	Restaurar operaciones rápidamente
Sistemas afectados	Minimizar propagación
Disponibilidad operativa	Mejorar resiliencia

7.3 Mejoras Recomendadas

Técnicas

- Arquitectura Zero Trust.
- SOC interno o tercerizado.
- Automatización SOAR.
- Backups inmutables.

Organizacionales

- Simulacros periódicos.
- Actualización del plan IR.
- Capacitación continua.

TechCo debe actualizar periódicamente su Plan de Respuesta a Incidentes (IR Plan) incorporando las lecciones aprendidas del ataque de ransomware, mejorando procedimientos, roles, tecnologías y mecanismos de comunicación, con el objetivo de fortalecer la capacidad de detección, contención y recuperación frente a futuros incidentes.

Normativas

Alineación con:

- National Institute of Standards and Technology
- International Organization for Standardization
- GDPR y normativas locales.

8. Conclusión

El ataque sufrido por TechCo demuestra cómo una combinación de errores humanos, controles insuficientes y ausencia de monitoreo puede derivar en un incidente crítico de ransomware.

La implementación de un Plan de Respuesta basado en el marco NIST permite:

- Reducir riesgos.
- Mejorar la capacidad de detección.
- Contener incidentes rápidamente.
- Recuperar operaciones con mayor eficiencia.
- Fortalecer la resiliencia organizacional.

La ciberseguridad debe entenderse como un proceso continuo de prevención, monitoreo, respuesta y mejora permanente.